JÖNKÖPING UNIVERSITY
School of Engineering

LABORATION 4 – LAN- OCH ENDPOINT-SÄKERHET

Fjärde laborationen i kursen Nätverkssäkerhet tar upp säkerhet på det lokala nätverket och hos endpoints. Syftet med laborationen är att studenten ska lära sig att implementera olika typer av lösningar för att säkra upp det lokala nätverket. Vissa säkerhetslösningar ska också verifieras genom penetrationstestning.

1 Uppgift

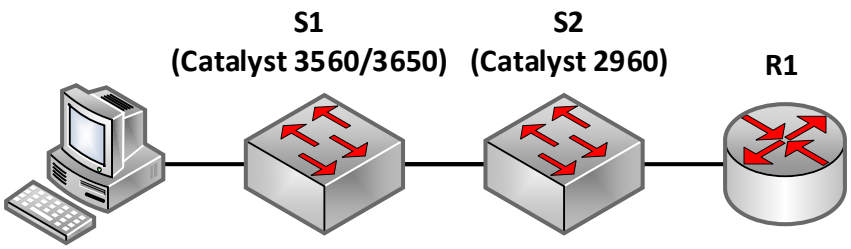
Uppgiften förutsätter deltagande på veckans föreläsning, samt genomläsning av kapitel 13 och 14 innan laborationen påbörjas. Labbhäftet *CCNA Security 2.0 – Student Lab Manual* rekommenderas som referenslitteratur. Laborationen är indelad i fyra delar:

1. Säkra upp det lokala nätverket (Cisco)
2. Testa säkerhet på lager 2
3. LAN-säkerhet i Fortinet
4. Säkra upp endpoints

I labbrapporten ska gruppen (min 2 personer, max 3 personer) bevisa att de har utfört alla fetmarkerade uppgifter i gula rutor, detta kan exempelvis vara med hjälp av skärmbilder, förklaringar, konfiguration och svar på frågor. Om inget är specificerat väljer ni själva hur ni vill bevisa att ni har utfört uppgiften. Om laborationen utförs utanför ordinarie laborationspass är det tillåtet att arbeta och lämna in enskilt. Säkerställ att skärmbilder är beskurna på ett bra sätt, inte för mycket och inte för lite. Såväl skärmbilder som täcker hela skärmen som skärmbilder där man endast ser en enstaka rad duger inte.

1.1 Säkra upp det lokala nätverket (Cisco)

Nu är det dags att implementera skydd för nätverksinfrastrukturen på det lokala nätverket. Sätt upp en miljö enligt *figur 1*. I denna del av laborationen ska Cisco Catalyst 2960 användas på S1, men switchen som ska köra Private VLAN (S2) måste vara en 3560 eller 3650. Datorn ska vara en gruppmedlems labbdator (det är givetvis okej att koppla in fler datorer), och routern kan vara av valfri modell men bör inte vara en brandvägg.



Figur 1. Topologi för laboration 4.

1. Konfigurera switcharna med följande funktioner:

- Konfigurera VLAN 100, 200 och 300 som access-VLAN. Skapa även VLAN 666 som ska användas som dummy-VLAN
- Konfigurera trunk mellan switcharna, tillåt ej VLAN 666 att kommunicera över trunken
- Konfigurera 10 stycken access-portar i VLAN 100 på respektive switch, detta VLAN ska användas av klienten och routern
- Trunkar ska använda ett specifikt VLAN för native VLAN som inte används någon annanstans (VLAN 123)
- DTP ska inte prata på någon port
- Access-portar ska använda Portfast och BPDU Guard
- Access-portar ska vara aktiverade med Port security, vid en violation ska porten stängas av, maximalt två MAC-adresser ska få kommunicera samtidigt
- Rapid-PVST ska användas som STP-protokoll
- S2 ska vara root-brygga i STP
- Loop guard ska vara aktiverat på lämpliga portar
- Root guard ska vara aktiverat på lämpliga portar
- Oanvända portar ska vara avstängda och satta i ett dummy-VLAN (VLAN 666)
- Konfigurera en valfri uppsättning av Private VLAN på S1 med minst en port i respektive roll (promiscious, community och isolated), använd nya VLAN för detta
- Sätt igång DHCP Snooping så att porten mot routern, samt upplänksportar, är satt som trusted (eftersom flera switchar används rekommenderas inställningarna *no ip dhcp snooping information option* och *ip dhcp relay information trust-all* på alla switchar i nätverket)
- Sätt igång Dynamic ARP Inspection (DAI)

Kopiera ett utdrag ur konfigurationsfilerna på switcharna som visar att ovanstående är uppfyllt.

Notera: Det är inte godkänt att kopiera hela konfigurationsfilerna, utan endast utvalda delar som bevisar ovanstående. Endast ett utdrag per port-typ bör inkluderas, flera portar med likadan konfiguration ska inte vara med. Dock rekommenderas ni att spara hela konfigurationen för både S1 och S2.

1.2 Testa säkerhet på lager 2

Man bör inte lita blint på att säkerhetsfunktionerna fungerar (eller att man inte har missat något), därför rekommenderas man att alltid testa säkerhetsåtgärderna innan de skickas ut i en produktionsmiljö. I denna del ska vi testa Port Security, DAI och DHCP Snooping med hjälp av Kali Linux.

Konfigurera routern och sätt i gång en DHCP-server i VLAN 100. Sätt ett lämpligt spann, t.ex. 10.0.100.0/24. Starta igång Kali Linux, maskinen ska i denna laboration vara inställt i bryggat läge. Se till att Kali får en IP-adress av DHCP-servern i spannet.

OBS: NU ÄR DET DAGS ATT UTFÖRA PENETRATIONSTESTNING. UTFÖR ENDAST DENNA TYP AV TESTER PÅ ENHETER SOM NI SJÄLV STYR ELLER SOM NI HAR FÅTT TILLÅTELSE ATT TESTA. TESTA ALDRIG UT MOT INTERNET DÅ DETTA EJ ÄR LAGLIGT.

Testa Port Security

Att testa Port Security är enkelt då det som ska utföras är att massvis med frames med spoofad MAC-adress ska skickas in till switchen. Inga inställningar behöver göras, utan skriv bara in *macof* i terminalen (OBS: FÅR ENDAST GÖRAS MOT DIN EGEN MILJÖ, ATT GÖRA DETTA NÅGON ANNAN STANS, EXEMPELVIS MOT LABBNÄTET, ÄR EJ TILLÅTET). I Hyper-V kan *macof* strula då hypervisorn ej tillåter spoofade MAC-adresser som standard. Gå därför in i inställningarna för nätverksadaptern och tillåt detta om du kör Hyper-V (vilket du inte borde om du följt laboration 1).

```
root@kali:~# macof
```

2. Bevisa att *Port Security* blockerade flooding-attacken (t.ex. med ett loggmeddelande). För att återställa porten behöver man stänga ned porten, och sedan starta i gång den igen.

Testa Dynamic ARP Inspection (DAI)

DAI använder vi främst för att skydda oss mot Man-in-the-Middle (MITM)-attacker på lager 2. För att testa dessa ska vi använda funktionen *arpspoof* i Kali Linux (OBS: FÅR ENDAST GÖRAS MOT DIN EGEN MILJÖ, ATT GÖRA DETTA NÅGON ANNAN STANS, EXEMPELVIS I LABBNÄTET, ÄR EJ TILLÅTET).

```
root@kali:~# arpspoof -i interface -t [target-ip] [target-gateway-ip]
```

Detta kommer göra att alla paket som vår målenhet vill skicka ut på Internet istället kommer att skickas till vår enhet. För att lyssna av paketen kan vi nu använda en paketsniffare, exempelvis *ettercap* eller *Wireshark*. Vid en fullbordad attack kommer det att märkas av direkt då trafiken slutar fungera för målenheten. Vill vi kunna avlyssna riktig trafik måste vi använda funktionen *IP forwarder* som ser till att trafiken också vidarebefordras ut på Internet. Eftersom vi endast vill testa DAI utför vi inte en fullskalig MITM-attack.

3. Bevisa att DAI blockerade ARP Spoofing-attacken.

Testa DHCP Snooping

Med hjälp av Metasploit kan vi sätta upp en ”rouge” DHCP-server. (OBS: FÅR ENDAST GÖRAS I DIN EGEN MILJÖ, ATT GÖRA DETTA NÅGON ANNAN STANS, EXEMPELVIS I LABBNÄTET, ÄR EJ TILLÅTET). Om det strular kan det vara så att Metasploit måste köras som root-användaren, du kan behöva skapa ett root-lösenord om du har senaste versionen av Kali.

msf5 > *use auxiliary/server/dhcp*

msf5 auxiliary(server/dhcp) > *set srvhost* (valfri IP-adress i nätverket)

msf5 auxiliary(server/dhcp) > *set netmask 255.255.255.0*

msf5 auxiliary(server/dhcp) > *set dhcpipstart 192.168.0.10*

msf5 auxiliary(server/dhcp) > *set dhcpipend 192.168.0.20*

msf5 auxiliary(server/dhcp) > *exploit*

Skicka nu en DHCP-förfrågan från din labbdator med **ipconfig /renew** i kommandotolken. **Hint:** För att testa DHCP Snooping går det också att sätta upp en helt vanlig DHCP-server på en router och sätta porten i *untrusted*.

4. Bevisa att DHCP Snooping blockerade paketen från den ogiltiga DHCP-servern.

1.3 LAN-säkerhet i Fortinet

Vissa av dessa funktioner vi testat ovan fungerar såklart även på FortiSwitch.

5. Beskriv hur följande två tekniker konfigureras på en FortiSwitch:

- Port security (kallas MAC learning limit i FortiSwitch)
- BPDU Guard

För att spara lite tid behöver ni inte testa teknikerna ovan rent praktiskt. Om ni ändå vill testa väljer ni själva om ni konfigurerar FortiSwitchen fristående, eller via en FortiGate (se labb 2.1). Precis som en FortiGate är FortiSwitch från fabrik tillgänglig via en IP-adress, 192.168.1.99. Konfigurera en statisk adress i samma nätverk. Om du inte når switchen kan du behöva ansluta via konsolkabel. Notera att PuTTY måste vara inställd på 115200 i *baud rate*. På nätet hittar du hur du återställer fabrikskonfigurationen (eller ändrar IP-adress).

1.4 Säkra upp endpoints

En nyckeldel för att säkra upp endpoints (slutenheter) är bland annat antivirus, brandvägg, kryptering och backup. I denna del av laborationen kommer vi att fokusera på antivirus.

Antivirus

När det gäller antivirus pågår det en debatt inom säkerhetscommunityn om tredjeparts-antivirus är onödigt och/eller skadligt. I en väldelad artikel på Gizmodo hävdar artikelförfattaren att dessa programvaror har spelat ut sin roll, och att operativsystemens inbyggda antivirus tillsammans med säkra surfvanor är det effektivaste skyddet mot skadlig kod. Även säkerhetsexperten Steve Gibson som

driver podcasten *Security Now!* har kommit ut som motståndare till tredjeparts-antivirus. Detta är en pågående debatt, och det finns många välkända namn på båda sidorna.

En fara som ofta tas upp angående antivirus-programvaror är att de ofta har full behörighet till alla resurser på en dator, detta innebär att alla sårbarheter i antivirus-programvaran kan öppna upp hela datorn för en hacker. Ett exempel på en sårbarhet i antivirus-programvaror är attacken *DoubleThink*. denna typ av sårbarheter rekommenderar ändå många säkerhetsexperter att man använder någon typ av tredjeparts-antivirus eftersom det inbyggda skyddet inte ger ett fullgott skydd.

Det de flesta experterna är dock helt överens om är att det bästa skyddet inte är antivirus-mjukvaror, i stället får vi det bästa skyddet genom att hantera webbsidor, mail och annat med stor försiktighet.

6. Bilda er en egen uppfattning om tredjeparts-antivirus genom att skumma igenom följande kandidatuppsats, ni behöver dock inte läsa kapitel 5 i detalj:

Baker, E. (2018). *Evaluating the Necessity of Third-Party Antivirus Software* (Kandidatuppsats, Högskolan i Skövde, Institutionen för informationsteknologi). Nås via DiVA.

Hitta ytterligare minst en vetenskaplig källa för att fördjupa er inom området. Rekommenderade sökord: ”antivirus software”, ”antimalware”, ”commercial antivirus”.

Vad drar ni för slutsats kring användningen av tredjeparts-antivirus? Skriv ned gruppens slutsats. Använd referenser (enligt APA) vid hänvisning till litteraturen ovan, tydliggör också vilka som är era egna åsikter.

Goda vanor

Som tidigare nämnt är tekniska åtgärder bara en första barriär för att skydda sig. Det är alltid goda vanor vid dator- och telefonanvändning som kommer att vara det starkaste skyddet. En användbar guide för detta är *”The Motherboard Guide to Not Getting Hacked”* av Motherboard. Den riktar sig särskilt till er som är lite extra paranoida. Ni kan läsa mer här: The Motherboard Guide to Not Getting Hacked

7. Nämn fem viktiga lärdomar från *”The Motherboard Guide to Not Getting Hacked”*.